INSA INSTITUT NATIONAL DES SCIENCES APPLIQUÉES HAUTS-DE-FRANCE

Université Polytechnique HAUTS-DE-FRANCE

RAPPORT DU PROJET

CTF HTB NOCTURNAL

&

MemLabs Lab 5





2024-2025

Togola Daouda

1 Méthodologie

1.1 Scan initial

J'ai utilisé nmap pour lister les différents services 10.10.11.64

```
┌──(hack㉿Hack)-[~]
└─$ nmap -sC -sV -Pn 10.10.11.64
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-05 08:46 EDT
Nmap scan report for nocturnal.htb (10.10.11.64)
Host is up (0.025s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.12 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 20:26:88:70:08:51:ee:de:3a:a6:20:41:87:96:25:17 (RSA)
|   256 4f:80:05:33:a6:d4:22:64:e9:ed:14:e3:12:bc:96:f1 (ECDSA)
|_  256 d9:88:1f:68:43:8e:d4:2a:52:fc:f0:66:d4:b9:ee:6b (ED25519)
80/tcp open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Welcome to Nocturnal
|_http-server-header: nginx/1.18.0 (Ubuntu)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.06 seconds
```

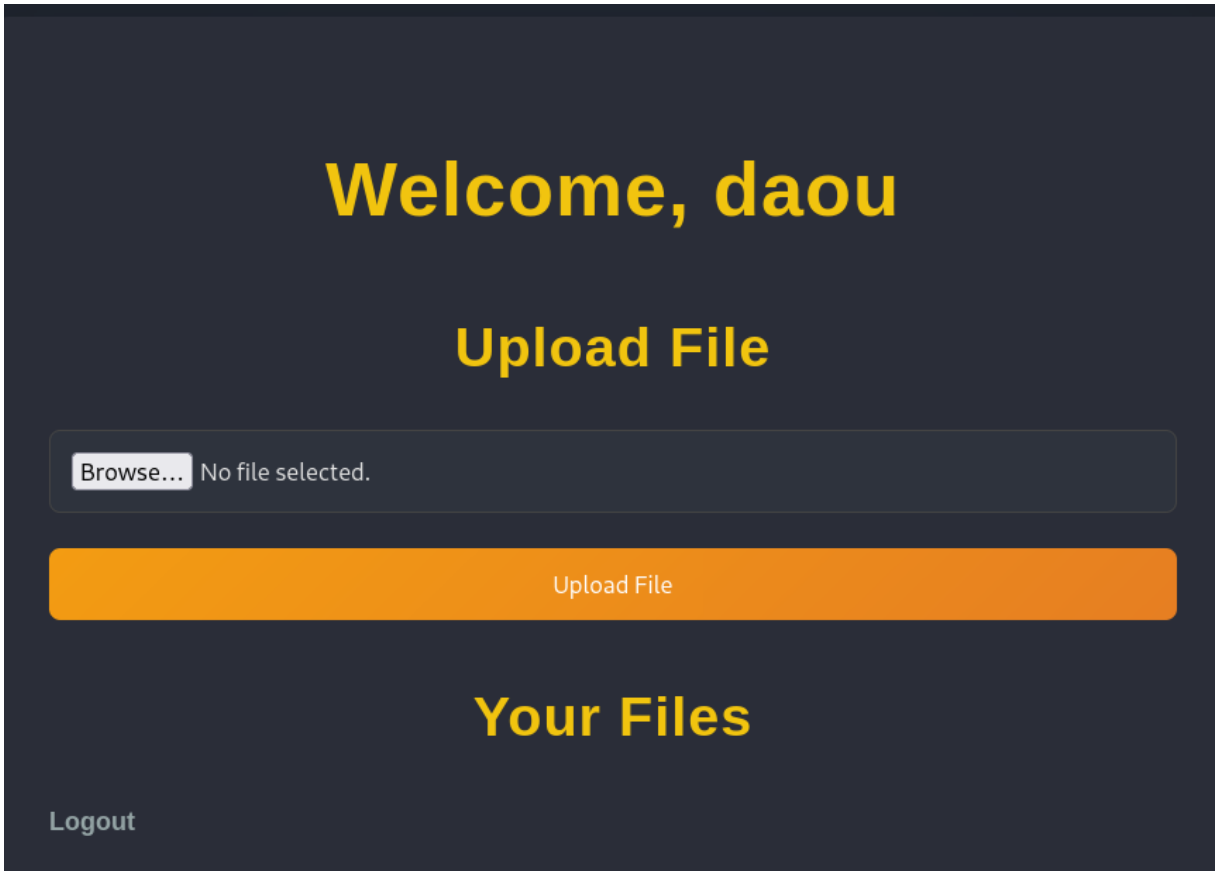
Apres mon scan initial avec **nmap** sur l'adresse j'ai rapidement vu deux services ouverts : un site web sur le port 80 et SSH sur le port 22.

1.2 Énumération web

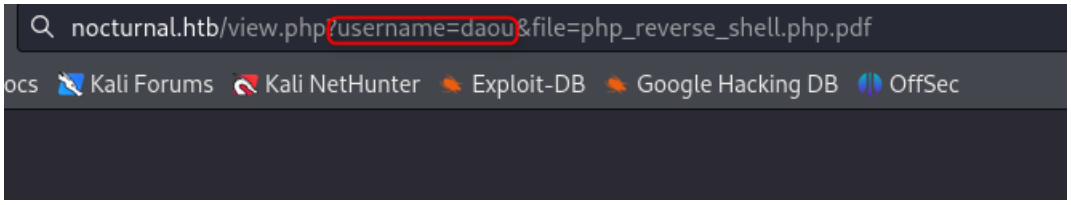
Ensuite j'ai utilisé Gobuster pour énumérer le site pour voir les différents pages du site

```
┌──(hack㉿Hack)-[~]
└─$ gobuster dir -u http://nocturnal.htb -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://nocturnal.htb
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/admin.php            (Status: 302) [Size: 0] [--> login.php]
/backups              (Status: 301) [Size: 178] [--> http://nocturnal.htb/backups/]
/index.php            (Status: 200) [Size: 1524]
/uploads              (Status: 403) [Size: 162]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

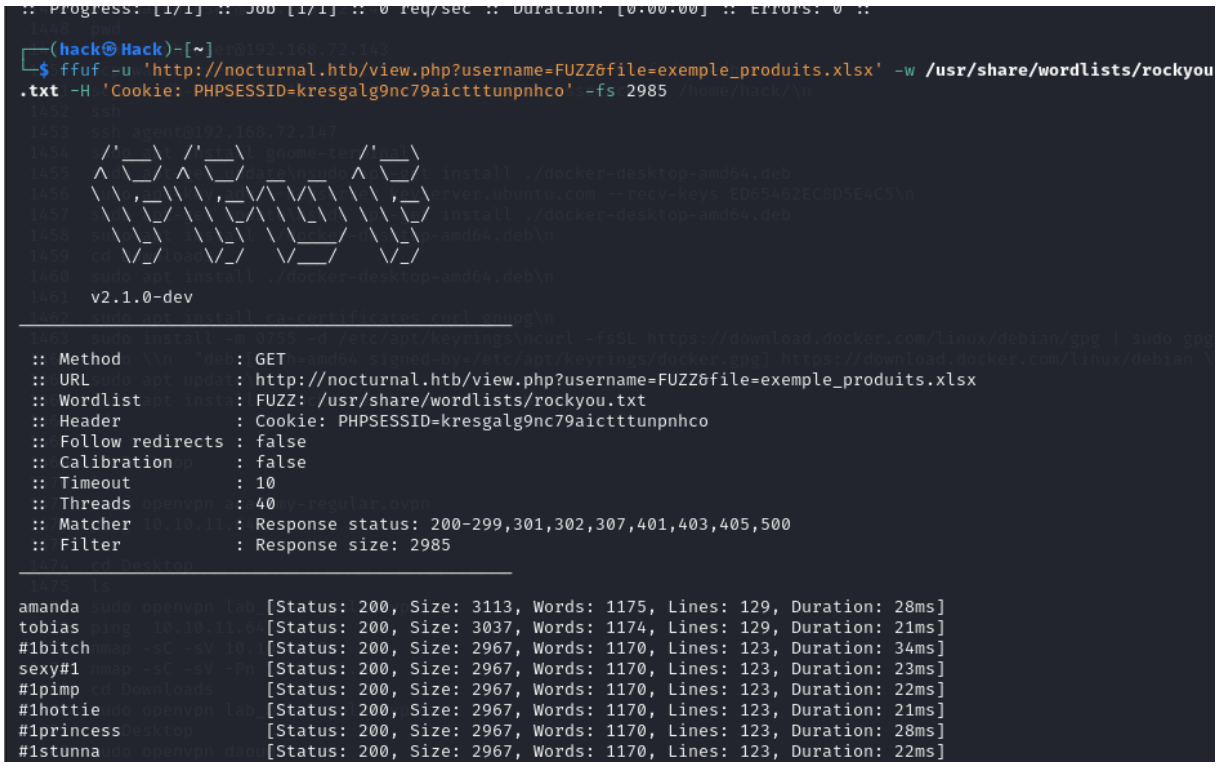
J'ai d'abord créé un compte utilisateur basique pour comprendre le workflow : inscription → upload → téléchargement.



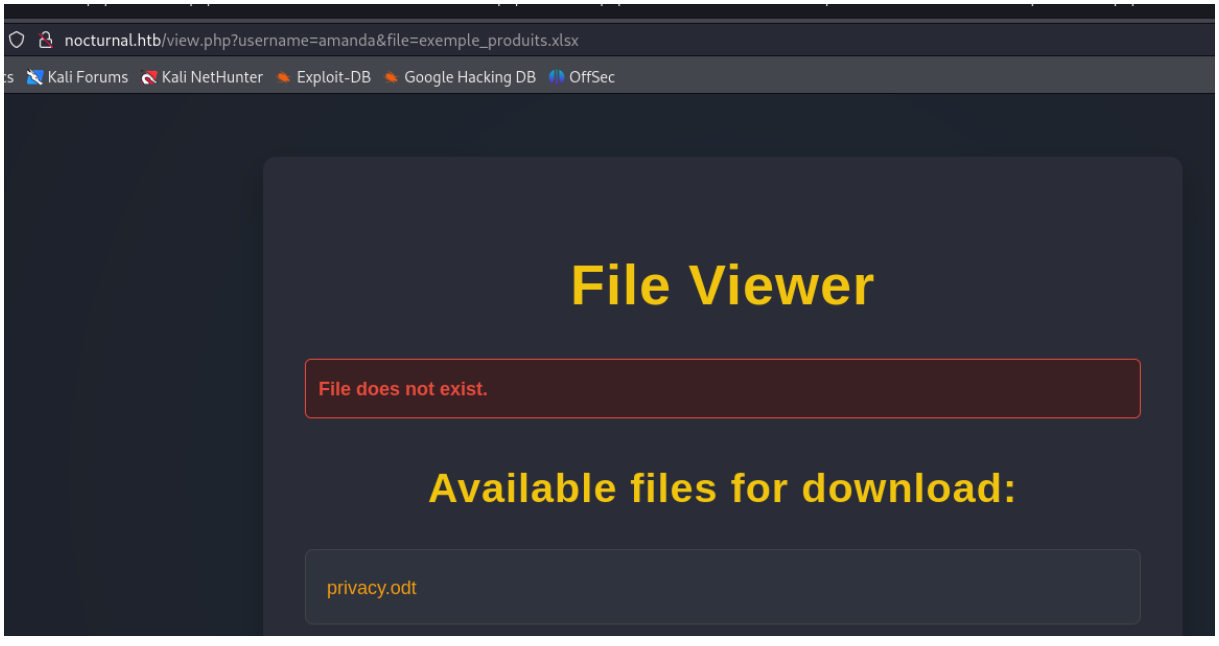
En regardant url du fichier j'ai compris qu'on pouvait récupérer les fichiers présent sur le serveur, à condition de connaître le nom de l'utilisateur.



Plutôt que de deviner manuellement les noms, j'ai lancé un petit brute force sur **http://nocturnal.htb/view.php?username=&file=exemple_produits.xlsx avec l'outils ffuf** et c'est là que j'ai découvert plusieurs fichiers correspondant à des utilisateurs, dont une certaine amanda.



Une fois que j'ai saisi ce nom amanda dans mon l'url j ai vu un fichier privacy.odt

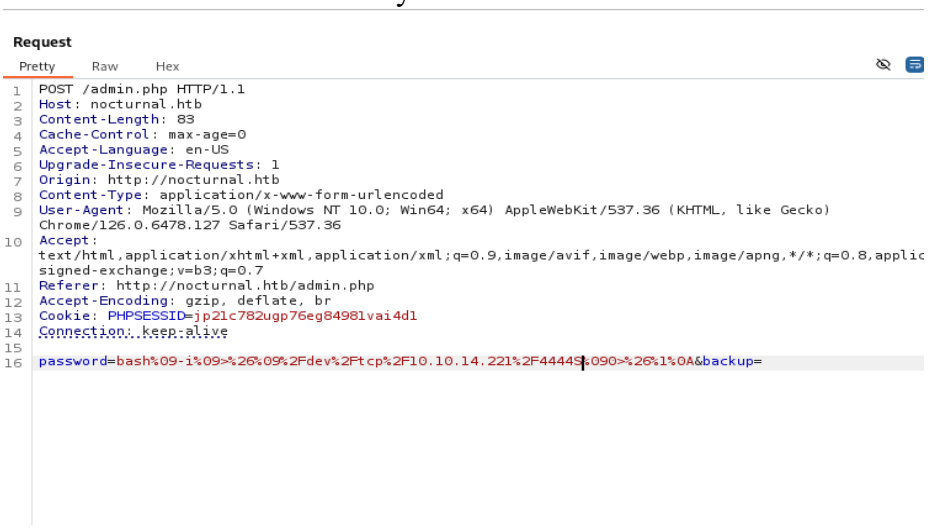


En téléchargeant le document **privacy.odt** d'amandine, j'ai extrait son contenu (et j'ai ouvert le **content.xml**. Au milieu du markup, un mot de passe était clairement visible – bingo ! Grâce à lui, je suis entré dans le panneau d'administration.

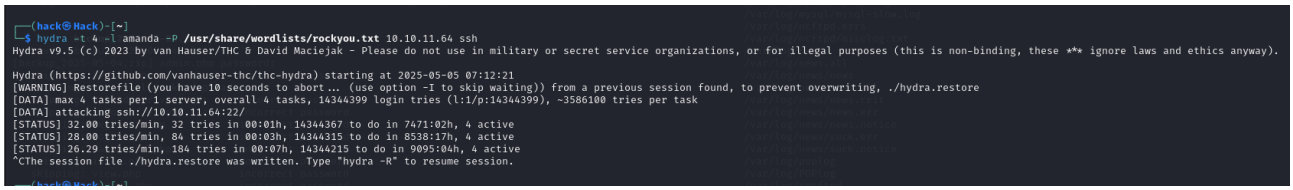




J'ai essayé d'exploiter cette fonction pour injecter des commandes via Burp Suite) en encodant différents payloads dans le champ "mot de passe", mais sans succès. Il semble qu'un filtrage empêche l'exécution directe de commandes système.



J’ai aussi tenté de brute-forcer le **SSH**, en utilisant des noms d’utilisateurs comme **amanda** et **tobias**, mais ça n’a rien donné, et c’était très long. J’ai finalement abandonné.




```
┌──(hack㉿Hack)-[~]
└─$ hydra -t 4 -l tobias -P /usr/share/wordlists/rockyou.txt 10.10.11.64 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizatio
ns, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-05 09:06:28
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session foun
d, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.10.11.64:22/
[STATUS] 40.00 tries/min, 40 tries in 00:01h, 14344359 to do in 5976:49h, 4 active
[STATUS] 28.00 tries/min, 84 tries in 00:03h, 14344315 to do in 8538:17h, 4 active
[STATUS] 26.29 tries/min, 184 tries in 00:07h, 14344215 to do in 9095:04h, 4 active
[STATUS] 25.60 tries/min, 384 tries in 00:15h, 14344015 to do in 9338:34h, 4 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
```

J’ai tenté aussi le fil inclusion manuellement et avec ffuf je n’ai pas pu

MemLabs Lab 5

2 Choisir le bon profil

D'abord, j'ai lancé imageinfo :

```
┌──(hack㉿Hack)-[~/volatility]
└─$ python2.7 vol.py -f /home/hack/Desktop/MemoryDump_Lab5.raw imageinfo

Volatility Foundation Volatility Framework 2.6.1
INFO    : volatility.debug    : Determining profile based on KDBG search...
          Suggested Profile(s) : Win7SP1x64, Win7SP0x64, Win2008R2SP0x64, Win2008R2SP1x64_24000, Win2008R2SP1x64_23418, Win2008R2SP1x64, Win7SP1x64_24000, Win7SP1x64_23418
                     AS Layer1 : WindowsAMD64PagedMemory (Kernel AS)
                     AS Layer2 : FileAddressSpace (/home/hack/Desktop/MemoryDump_Lab5.raw)
                      PAE type : No PAE
                           DTB : 0x187000L
                          KDBG : 0xf800028460a0L
          Number of Processors : 1
     Image Type (Service Pack) : 1
                KPCR for CPU 0 : 0xfffff80002847d00L
             KUSER_SHARED_DATA : 0xfffff78000000000L
           Image date and time : 2019-12-20 03:47:57 UTC+0000
     Image local date and time : 2019-12-20 09:17:57 +0530
```

Volatility m'a alors proposé plusieurs profils Windows que j'ai tester un a un, parmi les profiles **Win7SP1x64** correspondait exactement à l'OS.

3 Repérage des processus suspects

Avec le bon profil en place, j'ai listé les processus

```
┌──(hack㉿Hack)-[~/volatility]
└─$ python2.7 vol.py -f /home/hack/Desktop/MemoryDump_Lab5.raw --profile=Win7SP1x64 pslist
Volatility Foundation Volatility Framework 2.6.1
Offset(V)          Name                    PID   PPID   Thds     Hnds   Sess  Wow64 Start                          Exit
------------------ -------------------- ------ ------ ------ -------- ------ ------ ------------------------------ ------------------------------
0xfffffa8000ca0040 System                    4      0     80      562 ------      0 2019-12-20 03:41:40 UTC+0000
0xfffffa80014b9040 smss.exe                248      4      3       37 ------      0 2019-12-20 03:41:40 UTC+0000
0xfffffa8000d96b30 csrss.exe               320    312     10      471      0      0 2019-12-20 03:41:45 UTC+0000
0xfffffa8001c5d060 csrss.exe               368    360      8      173      1      0 2019-12-20 03:41:47 UTC+0000
0xfffffa8001c6b060 psxss.exe               376    248     18      786      0      0 2019-12-20 03:41:47 UTC+0000
0xfffffa8001c775a0 winlogon.exe            416    360      3      108      1      0 2019-12-20 03:41:48 UTC+0000
0xfffffa8001c7c060 wininit.exe             428    312      3       75      0      0 2019-12-20 03:41:48 UTC+0000
0xfffffa8001c7bb30 services.exe            484    428      8      213      0      0 2019-12-20 03:41:50 UTC+0000
0xfffffa8001cb9880 lsass.exe               492    428      9      761      0      0 2019-12-20 03:41:50 UTC+0000
0xfffffa8001cbc4a0 lsm.exe                 500    428     10      171      0      0 2019-12-20 03:41:50 UTC+0000
0xfffffa8001ce6b30 svchost.exe             588    484     10      357      0      0 2019-12-20 03:41:54 UTC+0000
0xfffffa8001d4cb30 VBoxService.ex          656    484     13      135      0      0 2019-12-20 03:41:55 UTC+0000
0xfffffa8001d63b30 svchost.exe             724    484      8      282      0      0 2019-12-20 03:41:56 UTC+0000
0xfffffa8001da1240 svchost.exe             820    484     23      590      0      0 2019-12-20 03:41:57 UTC+0000
0xfffffa8001dba060 svchost.exe             856    484     28      535      0      0 2019-12-20 03:41:58 UTC+0000
0xfffffa8001dc2b30 svchost.exe             880    484     33      983      0      0 2019-12-20 03:41:58 UTC+0000
0xfffffa8000cf5b30 audiodg.exe             968    820      6      131      0      0 2019-12-20 03:42:00 UTC+0000
0xfffffa8001e1cb30 svchost.exe             340    484     22      504      0      0 2019-12-20 03:42:03 UTC+0000
0xfffffa8001e6c700 svchost.exe            1044    484     16      381      0      0 2019-12-20 03:42:04 UTC+0000
0xfffffa8001ee1060 spoolsv.exe            1232    484     13      283      0      0 2019-12-20 03:42:09 UTC+0000
0xfffffa8001efbb30 svchost.exe            1272    484     19      307      0      0 2019-12-20 03:42:10 UTC+0000
0xfffffa8001f775f0 svchost.exe            1372    484     22      303      0      0 2019-12-20 03:42:12 UTC+0000
0xfffffa8001f93b30 TCPSVCS.EXE            1416    484      4       97      0      0 2019-12-20 03:42:13 UTC+0000
0xfffffa8001dbf350 taskhost.exe           2012    484      8      189      1      0 2019-12-20 03:43:19 UTC+0000
0xfffffa8002117b30 taskeng.exe            1140    880      4       79      0      0 2019-12-20 03:43:19 UTC+0000
0xfffffa8002170b30 dwm.exe                1172    856      5       71      1      0 2019-12-20 03:43:19 UTC+0000
0xfffffa8002198b30 explorer.exe           1396   1180     30      758      1      0 2019-12-20 03:43:19 UTC+0000
0xfffffa8002206890 VBoxTray.exe            528   1396     12      139      1      0 2019-12-20 03:43:25 UTC+0000
0xfffffa800222d7a0 SearchIndexer.         1800    484     13      710      0      0 2019-12-20 03:43:36 UTC+0000
0xfffffa80022a9b30 wmpnetwk.exe           1928    484     16      510      0      0 2019-12-20 03:43:40 UTC+0000
0xfffffa8001ec57c0 svchost.exe            2296    484      9      355      0      0 2019-12-20 03:43:45 UTC+0000
0xfffffa8001c3e910 WmiPrvSE.exe           2572    588      6      109      0      0 2019-12-20 03:43:56 UTC+0000
0xfffffa800209b760 sppsvc.exe             2940    484      4      141      0      0 2019-12-20 03:44:24 UTC+0000
0xfffffa8000f7a630 csrss.exe              1988    364      7      219      2      0 2019-12-20 03:46:42 UTC+0000
0xfffffa8000f82060 winlogon.exe           2120    364      4      113      2      0 2019-12-20 03:46:42 UTC+0000
0xfffffa8000fcd8e0 taskhost.exe           1968    484      9      150      2      0 2019-12-20 03:46:49 UTC+0000
0xfffffa8000fb34d0 dwm.exe                2360    856      5       71      2      0 2019-12-20 03:46:49 UTC+0000
0xfffffa80010213d0 explorer.exe           1580   2256     40     1007      2      0 2019-12-20 03:46:49 UTC+0000
0xfffffa800105ab30 VBoxTray.exe           2144   1580     13      138      2      0 2019-12-20 03:46:50 UTC+0000
0xfffffa8000f97a20 WinRAR.exe             2924   1580      6      210      2      0 2019-12-20 03:47:13 UTC+0000
0xfffffa80010b8060 notepad.exe            2744   1580      1       57      2      0 2019-12-20 03:47:21 UTC+0000
0xfffffa8000eeb060 DumpIt.exe             2208   1580      2       45      2      1 2019-12-20 03:47:39 UTC+0000
0xfffffa8000eab790 conhost.exe            2612   1988      2       51      2      0 2019-12-20 03:47:40 UTC+0000
0xfffffa800108cb30 NOTEPAD.EXE            2724   1580      1       39      2      1 2019-12-20 03:47:53 UTC+0000
0xfffffa800109f060 svchost.exe            2632    484      7       82      0      0 2019-12-20 03:47:54 UTC+0000
```

En parcourant la liste, deux noms ont sauté aux yeux- qui semblait suspect, **WinRAR.exe**, qui trahit la présence d'une archive en mémoire et plusieurs instances de **notepad.exe**, dont l'une semblait pointer vers un exécutable inattendu.

J'ai ensuite voulu comprendre **comment** ces programmes avaient été lancés avec le command cmdline

```
┌──(hack㉿Hack)-[~/volatility]
└─$ python2.7 vol.py -f /home/hack/Desktop/MemoryDump_Lab5.raw --profile=Win7SP1x64 cmdline
Volatility Foundation Volatility Framework 2.6.1
************************************************************************
System pid:      4
************************************************************************
smss.exe pid:    248
Command line : \SystemRoot\System32\smss.exe
************************************************************************
csrss.exe pid:    320
Command line : %SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows SharedSection=1024,20480,768 Windows=On SubSystemTyp
alization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16
************************************************************************
csrss.exe pid:    368
Command line : %SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows SharedSection=1024,20480,768 Windows=On SubSystemTyp
alization,2 ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16
************************************************************************
psxss.exe pid:    376
Command line : %SystemRoot%\system32\psxss.exe
************************************************************************
winlogon.exe pid:    416
Command line : winlogon.exe
************************************************************************
wininit.exe pid:    428
Command line : wininit.exe
************************************************************************
services.exe pid:    484
Command line : C:\Windows\system32\services.exe
************************************************************************
lsass.exe pid:    492
Command line : C:\Windows\system32\lsass.exe
************************************************************************
lsm.exe pid:    500
Command line : C:\Windows\system32\lsm.exe
************************************************************************
```

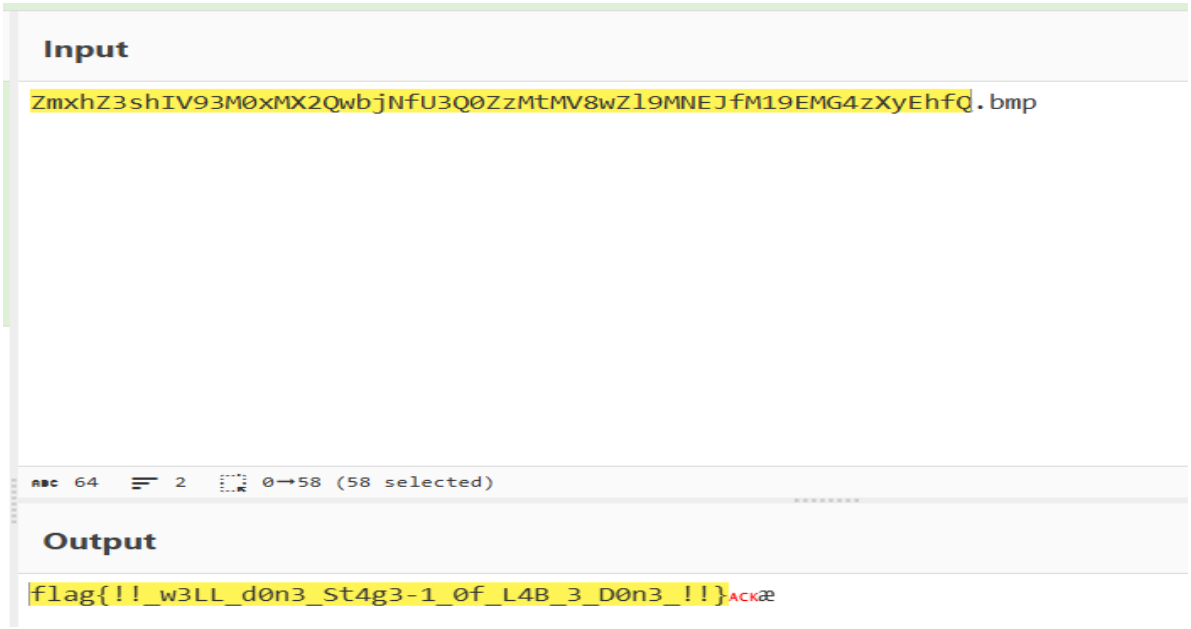
```
WinRAR.exe pid:   2924
Command line : "C:\Program Files\WinRAR\WinRAR.exe" "C:\Users\SmartNet\Documents\SW1wb3J0YW50.rar"
************************************************************************
notepad.exe pid:   2744
Command line : "C:\Windows\system32\notepad.exe"
************************************************************************
DumpIt.exe pid:   2208
Command line : "C:\Users\SmartNet\Downloads\DumpIt\DumpIt.exe"
************************************************************************
conhost.exe pid:   2612
Command line : \??\C:\Windows\system32\conhost.exe
************************************************************************
NOTEPAD.EXE pid:   2724
```

J'ai vu que WinRAR.exe a été exécutée pour ouvrir une archive RAR SW1wb3J0YW50.rar

Donc j'ai ensuite utilisé iehistory pour voir le fichier en code base 64

```
┌──(hack㉿Hack)-[~/volatility]
└─$ python2.7 vol.py -f /home/hack/Desktop/MemoryDump_Lab5.raw --profile=Win7SP1x64  iehistory
Volatility Foundation Volatility Framework 2.6.1
**************************************************
Process: 1396 explorer.exe
Cache type "URL " at 0x28c5000
Record length: 0x100
Location: Visited: Alissa Simpson@file:///C:/Users/Alissa%20Simpson/Documents/Important.rar
Last modified: 2019-12-11 14:37:23 UTC+0000
Last accessed: 2019-12-11 14:37:23 UTC+0000
File Offset: 0x100, Data Offset: 0x0, Data Length: 0xbc
**************************************************
Process: 1396 explorer.exe
Cache type "URL " at 0x28c5100
Record length: 0x100
Location: Visited: Alissa Simpson@file:///C:/Users/Alissa%20Simpson/Downloads/SW1wb3J0YW50.rar
Last modified: 2019-12-11 10:03:48 UTC+0000
Last accessed: 2019-12-11 10:03:48 UTC+0000
File Offset: 0x100, Data Offset: 0x0, Data Length: 0xc0
**************************************************
Process: 1396 explorer.exe
Cache type "URL " at 0x28c5200
Record length: 0x100
Location: Visited: Alissa Simpson@https://notifier.rarlab.com/?language=English&source=RARLAB&landingpage=first&version=580&architecture=64
Last modified: 2019-12-11 10:03:52 UTC+0000
Last accessed: 2019-12-11 10:03:52 UTC+0000
File Offset: 0x100, Data Offset: 0x0, Data Length: 0xec
**************************************************
Process: 1396 explorer.exe
Cache type "URL " at 0x28c5300
Record length: 0x100
Location: Visited: Alissa Simpson@file:///C:/Users/Alissa%20Simpson/stAg3_5.txt
Last modified: 2019-12-11 10:04:00 UTC+0000
Last accessed: 2019-12-11 10:04:00 UTC+0000
rocess: 1396 explorer.exe
ache type "URL " at 0x28c5900
ecord length: 0x100
ocation: Visited: Alissa Simpson@file:///C:/Users/Alissa%20Simpson/Pictures/ZmxhZ3shIV93M0xMX2QwbjNfU3Q0ZzMtMV8wZl9MNEJfM19EMG4zXyEhfQ.bmp
ast modified: 2019-12-19 08:35:18 UTC+0000
ast accessed: 2019-12-19 08:35:18 UTC+0000
ile Offset: 0x100, Data Offset: 0x0, Data Length: 0xec
**************************************************
rocess: 1396 explorer.exe
ache type "URL " at 0x28c5a00
ecord length: 0x100
ocation: Visited: Alissa Simpson@file:///C:/Users/Alissa%20Simpson/Pictures/ZmxhZ3shIV93M0xMX2QwbjNfU3Q0ZzMtMV8wZl9MNEJfNV9EMG4zXyEhfQ.bmp
ast modified: 2019-12-20 03:46:09 UTC+0000
ast accessed: 2019-12-20 03:46:09 UTC+0000
ile Offset: 0x100, Data Offset: 0x0, Data Length: 0xec
**************************************************
rocess: 1396 explorer.exe
```

Ensuite j'ai décodé avec cyber chef



flag{!!_w3LL_d0n3_St4g3-1_0f_L4B_3_D0n3_!!